ConnectSphere
Cybersecurity Governance Assessment

Prioritized risk analysis and corrected architecture | Sets 1 and 2

Prepared for: ConnectSphere Security Due Diligence

Role: Independent Cybersecurity Governance Consultant

Scope: Confidentiality, integrity, availability, access control, secure development, compliance, and monitoring.

Assessment outcome

The supplied diagrams show material weaknesses in transport security, API and administrator access, database exposure, input handling, secret management, and operational monitoring. The corrected designs apply defense in depth, least privilege, secure development practices, and auditable controls. Set 1 and Set 2 are documented separately so the relevant section can be submitted for the assigned architecture.

Contents

1. Set 1 governance review card and review summary

2. Set 1 corrected architecture diagram

3. Set 2 governance review card and review summary

4. Set 2 corrected architecture diagram

Set 1: Cybersecurity Governance Review Card

Project: ConnectSphere Professional Event Networking MVP

Deliverable 1. Prioritized risk findings

Finding	Issue and principle	Impact	Suggested fix / mitigation
Confidentiality	**Finding:** HTTP is unencrypted, web servers and a database appear publicly reachable, and the admin dashboard has no authentication. **Principles:** CIA confidentiality and least privilege.	PII, phone numbers, and account credentials could be intercepted or exposed. Public administration access could enable broad data disclosure.	Enforce HTTPS/TLS; place databases in private subnets; restrict network rules; require administrator MFA, role based access, and least privilege.
Integrity	**Finding:** Backend SQL queries are shown without prepared statements, and request validation is not defined. **Principles:** Input validation and secure SDLC.	SQL injection or malformed input could alter or delete records, bypass authentication, or corrupt user and event data.	Use parameterized queries or a safe ORM; validate inputs against server side schemas; encode output; review code and run security tests before release.
Availability	**Finding:** No rate limiting, audit logging, alerting, or incident response path is shown. **Principles:** CIA availability and defense in depth.	Abuse of APIs or SMS verification could exhaust resources and increase cost. Attacks may remain undetected and recovery may be delayed.	Apply rate limits and quotas to login, OTP, and API routes; add centralized logs and alerts; maintain backups, tested recovery, and an incident response playbook.

Monitoring and reporting recommendation

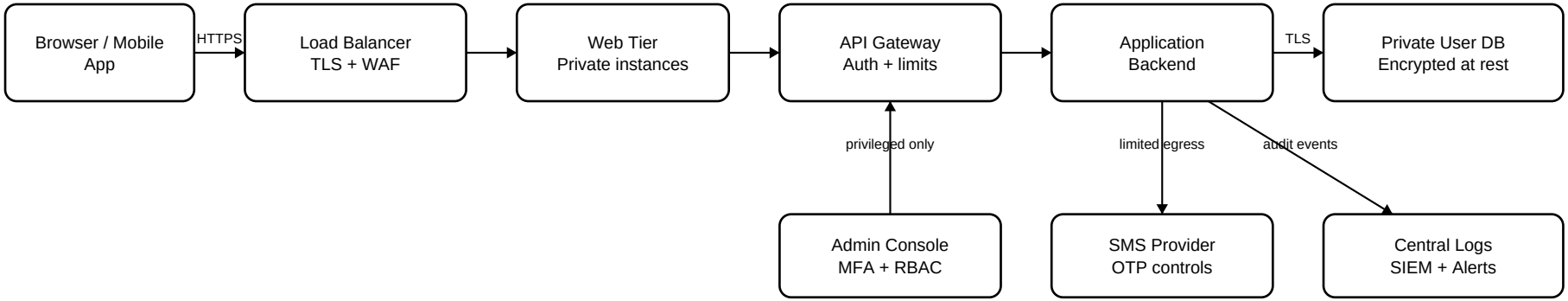
Metric to monitor	Visualization	Why it matters
Failed authentication and authorization rate: failed login or denied access events per 1,000 requests, tracked over time.	Line chart	A sustained increase can reveal credential attacks, access control failures, or misuse early enough for investigation.

Deliverable 3. Summary of review process

I reviewed the Set 1 diagram by tracing the user request path, application backend, SMS verification integration, databases, and administrator access. I prioritized risks by the sensitivity of personal information, the likelihood of exploitation, and the potential business impact. The CIA Triad classifies unencrypted traffic and exposed databases as confidentiality risks, unsafe SQL handling as an integrity risk, and missing rate limits and response capabilities as availability risks. The Principle of Least Privilege supports restricting database access to the backend service, separating administrator roles from ordinary users, and requiring multifactor authentication for privileged actions. Secure SDLC controls should include server side input validation, parameterized database queries, peer review, dependency checks, and security tests before deployment. HTTPS/TLS, private database networking, role based API authorization, and managed secrets reduce the chance that profile and event information will be disclosed or changed without permission. These controls support GDPR and CCPA expectations for reasonable safeguards and protection of personal information where the laws apply; legal applicability and specific obligations should be confirmed by counsel. I recommend monitoring the failed authentication and authorization rate as a time series. An access controlled dashboard with defined alert thresholds gives security and engineering teams a timely signal of brute force attempts or broken permissions. Logs should avoid unnecessary personal data, follow a retention policy, and be reviewed only by authorized staff. This approach makes security decisions traceable and supports accountable governance.

ConnectSphere Corrected Architecture | Set 1

Proposed secure design. Numbered annotations explain the corrections.



Trust boundary: public traffic ends at the protected load balancer. Databases and service interfaces remain private.

Additional controls: managed secrets, secure session cookies, session expiry, dependency scanning, and tested recovery.

1. Encrypt connections

HTTPS/TLS protects personal data in transit between clients and platform services.

2. Private data layer

Databases have no public route. Only the backend identity may connect on the required port.

3. Validate and authorize

Enforce API authentication, object level authorization, server side validation, and parameterized SQL.

4. Monitor privileged activity

Require admin MFA/RBAC, centralized audit logs, alerts, backups, and an incident response plan.

Set 2: Cybersecurity Governance Review Card

Project: ConnectSphere Professional Connection Platform V1

Deliverable 1. Prioritized risk findings

Finding	Issue and principle	Impact	Suggested fix / mitigation
Confidentiality	**Finding:** Traffic uses HTTP, an API key is stored in frontend code, and the administrator dashboard uses default credentials without authentication. **Principles:** CIA confidentiality and least privilege.	Traffic may be intercepted; frontend secrets can be extracted; default admin access can expose profiles, event attendance, and forum content.	Enforce HTTPS/TLS; remove secrets from frontend bundles and rotate exposed keys; use a server side secret manager; require unique admin accounts, MFA, and role based access.
Integrity	**Finding:** SQL queries are not parameterized and API authorization and content validation are not defined. **Principles:** Input validation, secure SDLC, and integrity.	Attackers may inject SQL, alter event records, impersonate users, or submit malicious forum content that bypasses moderation.	Use parameterized queries; validate schemas and ownership server side; enforce object level authorization; encode rendered content; audit moderation and privileged changes.
Availability	**Finding:** Email service has no rate limiting and centralized monitoring or incident response is not shown. **Principles:** CIA availability and resilience.	Automated requests can exhaust email quotas, create spam, increase costs, and degrade event or forum availability. Delayed detection extends outages.	Rate limit email and API requests per account and IP; add quotas, abuse detection, health checks, centralized logging and alerts; test backups and response procedures.

Monitoring and reporting recommendation

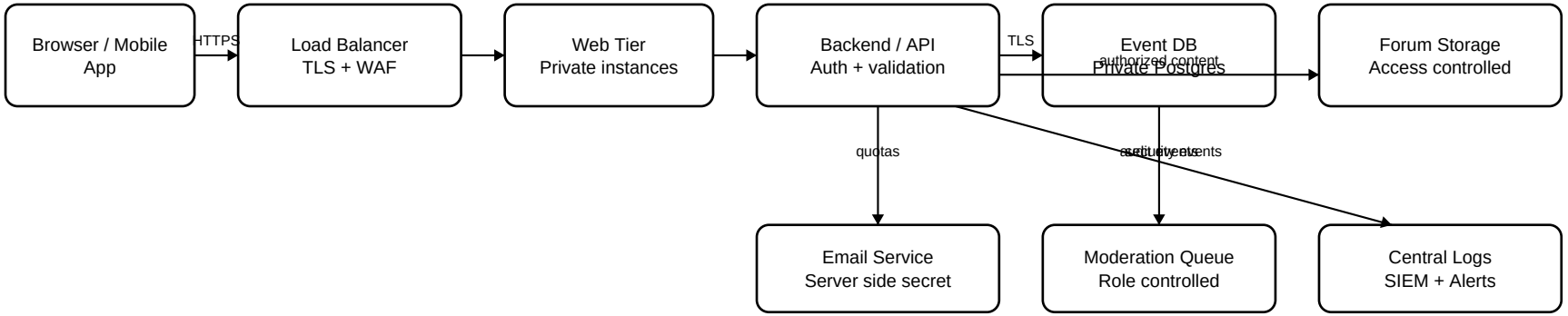
Metric to monitor	Visualization	Why it matters
Rate of API requests blocked by rate limits: throttled requests per minute, grouped by endpoint and source category.	Line chart	Spikes can expose automation, spam campaigns, or denial of service attempts before event and forum services degrade.

Deliverable 3. Summary of review process

I examined the Set 2 diagram from the browser entry point through the web tier, application backend, event database, email service, moderation queue, and forum storage. The review focused on realistic abuse paths rather than treating components in isolation. Under the CIA Triad, HTTP and exposed frontend API keys threaten confidentiality, unsafe SQL handling threatens integrity, and unrestricted email requests threaten availability. The Principle of Least Privilege requires the browser to hold no privileged API secret, each service to receive only the permissions it needs, and administrator access to use individual accounts, multifactor authentication, and role based permissions. Secure SDLC practices should require server side validation, parameterized queries, authorization checks for every protected object, code review, and automated tests for injection and access control flaws. The corrected design places databases behind private network controls, protects service credentials with a secret manager, and adds rate limits and centralized security logging. These measures strengthen protection for professional profile details, attendance records, and forum contributions. They support GDPR and CCPA security and accountability expectations where those laws apply, although legal counsel should confirm jurisdiction specific duties and notices. The recommended metric is the rate of API requests blocked by rate limits, viewed over time and grouped by endpoint. A spike can indicate scraping, spam, or denial of service behavior and help teams respond before users lose access to workshops or discussions. Logs should have defined owners, retention periods, and access restrictions. Incident response responsibilities, escalation contacts, and recovery tests should be documented so that security actions are timely, proportionate, and reviewable.

ConnectSphere Corrected Architecture | Set 2

Proposed secure design. Numbered annotations explain the corrections.



Forum posts and event records are accessible only through authorized service identities; databases are not publicly exposed.

Additional controls: secure session cookies, expiry and revocation, log retention, backup recovery tests, and incident response.

1. Remove frontend secrets

Keep API keys out of browser code. Rotate exposed credentials and use a server side secret manager.

2. Secure API and database

Use TLS, authentication, object level authorization, input schemas, and parameterized queries.

3. Limit abuse

Apply per account and per IP limits to API and email routes, with quotas and abuse alerts.

4. Secure administration

Replace default credentials with individual admin accounts, MFA, least privilege roles, and auditable moderation.